

ÉTUDE DE CAS — SPOTIFY

LIVRABLE 1

Rapport de diagnostic de maturité des données

Certification RNCP 41993 – Adrien COSSON

Bloc 1 - Concevoir et piloter la gouvernance des données et des systèmes d'IA

1. Introduction

Fondée en 2006 à Stockholm, Spotify est aujourd'hui l'un des leaders mondiaux du streaming audio. En 2023, la plateforme compte plus de 450 millions d'utilisateurs actifs (et 777 millions d'utilisateurs lors de la rédaction de ce rapport), dont 200 millions d'abonnés Premium, répartis dans plus de 180 pays. Son modèle économique repose sur deux offres : une offre gratuite financée par la publicité et une offre Premium sans publicité, payante par abonnement.

La donnée est au cœur de ce modèle. Chaque jour, Spotify collecte et traite de très gros volumes de données : historiques d'écoute, playlists, recherches, métadonnées des titres et des podcasts, informations d'abonnement et de facturation. Ces données alimentent le moteur de recommandation utilisant des algorithmes d'apprentissage automatique (Discover Weekly, Daily Mix), le ciblage publicitaire et les décisions stratégiques. C'est le principal avantage de Spotify face à Apple Music, Amazon Music ou YouTube Music.

Cependant, la croissance rapide de l'entreprise s'est faite sans cadre de gouvernance commun. Chaque département gère ses propres données, ce qui a créé des silos, des problèmes de qualité et des difficultés à respecter des réglementations de plus en plus exigeantes (RGPD, CCPA, etc.).

Ce rapport constitue la première étape de la stratégie de gouvernance des données de Spotify. Il a pour objectif d'évaluer le niveau de maturité actuel de l'entreprise, domaine par domaine, afin d'identifier ses points forts, ses faiblesses et les priorités d'action. Après une présentation de la méthode d'évaluation (section 2), les résultats sont détaillés pour chacun des dix domaines étudiés (section 3), puis les principaux défis sont synthétisés et priorisés (section 4). Ces conclusions serviront de base à la politique de gouvernance (Livrable 2) et au plan de mise en œuvre (Livrable 3).

2. Méthode

Le DMBOK (Data Management Body of Knowledge) est un référentiel mondial qui encadre la gestion des données d'entreprise. Structuré autour d'un noyau central dédié à la Gouvernance des données, il décrit les bonnes pratiques réparties en 10 domaines de connaissances interconnectés.

Ces spécialisations visent, entre autres, à définir les règles d'utilisation des données ; leur structuration (architecture et modélisation) ; les opérations de stockage et de sécurisation ; leur cycle de vie (intégration et interopérabilité) ; et enfin leur valorisation à travers la gestion des métadonnées (via des outils comme le Data Catalogue), la qualité des données et le Data Warehousing (analytique).

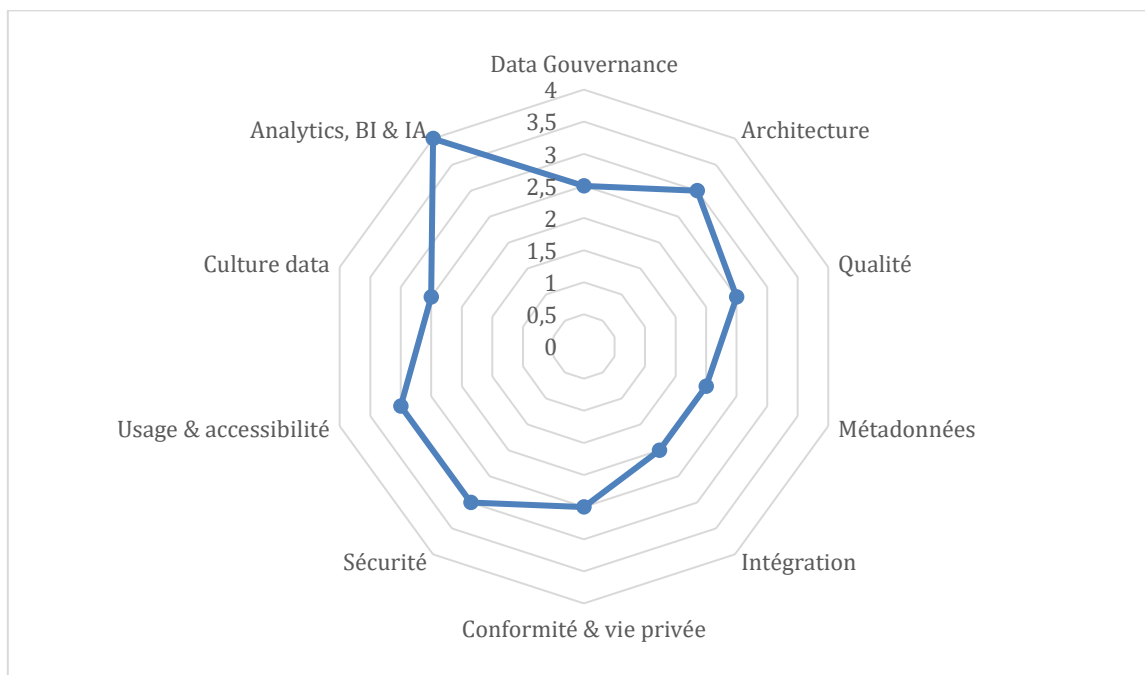
L'échelle de maturité utilisée est celle présentée dans le cours (Data maturity stages). Elle permet de noter de 1 à 5 la maturité de Spotify pour chaque domaine :

- **1 Aware** : l'importance des données est comprise, mais il n'existe ni processus ni politique
- **2 Reactive** : quelques processus locaux existent et corrigent les problèmes au cas par cas
- **3 Proactive** : les politiques sont définies et connues dans l'organisation, mais pas encore appliquées partout
- **4 Managed** : la gestion des données est maîtrisée, pilotée par des indicateurs, et la sécurité est contrôlée
- **5 Effective** : efficacité maximale, l'usage des données sert à améliorer les pratiques en continu.

L'évaluation reprend les 9 dimensions du Data Maturity Assessment Template fourni (gouvernance, qualité, architecture, conformité, usage et accessibilité, sécurité, culture data, intégration, analytics et BI). Elles sont complétées par la gestion des métadonnées, domaine du DMBOK dont dépend la documentation des données. Chaque note est associée à une description issue du Business Case (BC) fourni ou d'une source publique.

3. Résultats de l'évaluation de la maturité de Spotify

Cette partie récapitule dans un graphique ainsi qu'un tableau la notation du score de maturité de la Data Gouvernance de Spotify. S'en suit un descriptif pour chaque domaine de connaissance expliquant la décision de la notation.



Dimension	Notation
Data Gouvernance	2,5
Architecture	3
Qualité	2,5
Métadonnées	2
Intégration	2
Conformité & vie privée	2,5
Sécurité	3
Usage & accessibilité	3
Culture data	2,5
Analytics, BI & IA	4
Score global	≈ 2,7

Data Gouvernance — 2,5 / 5

Faiblesse : Absence de gouvernance commune dans les différents départements. Chacun utilise et gère ses propres données en utilisant ses propres règles internes. Cela conduit à la création de silos ainsi que la présence de plusieurs versions du même utilisateur.

Force : Spotify a une bonne connaissance de ses données. Des postes clés comme une équipe juridique, un Chief Data Officer (CDO) et Data Protection Officer (DPO) sont déjà en place.

- **Plan d'action** : Rédaction d'une politique de gouvernance autour de la donnée unifiée pour tous les départements. La création d'un comité de gouvernance permettrait grâce au CDO, aux Data Owners et Data Stewards de chaque département de veiller à son application.

Architecture — 3 / 5

Faiblesse : L'architecture est devenue complexe et chaque équipe a construit ses propres flux. Les identifiants changent d'un système à l'autre, ce qui empêche de suivre un utilisateur de la découverte d'un titre jusqu'à l'abonnement.

Force : L'infrastructure est solide et moderne (Data Lakes, bases relationnelles, stockage cloud) et traite de très gros volumes en temps réel.

- **Plan d'action** : Documenter l'architecture existante, harmoniser les schémas et les clés (identifiant utilisateur commun) et désigner un responsable pour chaque source de données.

Qualité — 2,5 / 5

Faiblesse : Le business case mentionne des préférences utilisateurs erronées et des métadonnées obsolètes qui dégradent les recommandations. Il n'y a ni indicateurs de qualité partagés ni tests systématiques, les données d'interaction ne sont pas captées de façon homogène.

Force : La donnée est au cœur du métier, donc les équipes sont déjà attentives à sa fiabilité, et chaque silo dispose d'une base de qualité correcte.

- **Plan d'action** : Définir des règles de qualité communes (complétude, exactitude, fraîcheur, doublons) avec des seuils par jeu de données, automatiser les contrôles dans les pipelines et suivre les résultats dans un tableau de bord.

Métadonnée — 2 / 5

Faiblesse : Absence de Data Catalogue et de glossaire commun. Les différents acteurs autour de la donnée dans les différents départements ne savent pas quelles données existent, qui en est le responsable ainsi que sa provenance ou encore s'il s'agit de données personnelles ou non.

Force : Chaque équipe connaît bien ses propres données, et ce savoir peut servir de point de départ à la documentation.

- **Plan d'action** : Mise en place d'un Data Catalogue comprenant un glossaire métier, le propriétaire (Data Owner) de chaque jeu de données, le « lineage » des flux critiques et un marquage des données personnelles.

Intégration — 2 / 5

Faiblesse : La présence de silos entraîne la duplication des données au sein des différents départements, avec des pipelines de traitement des données en double. Cela rend difficile aux différentes équipes d'avoir une vision complète et fiable de l'utilisateur.

Force : L'architecture est déjà en place afin d'ingérer de nombreux flux, et des sources de bonne qualité existent localement.

- **Plan d'action** : Création d'un identifiant utilisateur unique, mise en place d'un référentiel maître (MDM) et d'une plateforme d'intégration partagée, puis suppression progressive des pipelines en double.

Conformité & Vie Privée — 2,5 / 5

Faiblesse : Spotify a été sanctionné par l'autorité suédoise (amende d'environ 5 M€, IMY, juin 2023) parce que ses réponses aux demandes d'accès des utilisateurs étaient incomplètes et peu compréhensibles. Les mécanismes de consentement ne sont pas harmonisés entre les systèmes, et la conformité doit couvrir plus de 180 pays.

Force : Le siège étant en Suède, Spotify a choisi d'utiliser le RGPD comme cadre de référence. Les enjeux réglementaires sont connus, et un DPO et une équipe juridique sont en place.

- **Plan d'action** : Automatiser le traitement des demandes d'accès et de suppression, centraliser la gestion du consentement, fournir des réponses claires et traduites dans la langue de l'utilisateur, et organiser des audits réguliers et une veille réglementaire.

Sécurité — 3 / 5

Faiblesse : La sécurité repose sur le seul Head of Engineering, et la protection des données à chaque étape du traitement n'est pas garantie, alors que Spotify stocke des données de facturation sensibles.

Force : Le stockage cloud apporte un socle de sécurité solide, et chaque périmètre dispose déjà de ses propres protections.

- **Plan d'action** : Attribuer les accès par rôle (RBAC, Role-Based Access Control) selon le principe du moindre privilège, chiffrer les données sensibles (notamment les données de paiement), journaliser les accès et réaliser des audits de sécurité réguliers.

Usage & Accessibilité — 3 / 5

Faiblesse : Accéder aux données d'un autre service est lent et passe par des demandes manuelles. Le business case parle de « goulots d'étranglement ». L'absence de Data Catalogue conduit à une méconnaissance de la data stockée, sa structure et son accessibilité.

Force : L'usage des données est encouragé à tous les niveaux, et elles servent réellement à la prise de décision et à la personnalisation.

- **Plan d'action :** Créer un portail d'accès en libre-service relié au catalogue, avec des droits attribués selon la sensibilité des données.

Culture Data — 2,5 / 5

Faiblesse : La culture de la data est présente mais pas unifiée entre les départements, et il n'existe pas de programme de formation à la gouvernance (qualité, vie privée, règles d'accès). Le travail en silo et la duplication des données en sont les conséquences.

Force : La culture data-driven est réelle : le business case la présente comme un facteur clé du succès de Spotify.

- **Plan d'action :** Initier un programme de formation adapté à chaque profil et rôle (direction, métiers, techniques) et accessible à tous, et documenter clairement le cadre de gouvernance.

Analytics, BI & IA — 4 / 5

Faiblesse : Les silos et la qualité inégale des données limitent les analyses transverses. Certains indicateurs donnent des chiffres différents selon le tableau de bord, et rien n'encadre les biais ni l'explicabilité du moteur de recommandation.

Force : C'est le point fort de Spotify : un moteur de recommandation reconnu (Discover Weekly, Daily Mix) et des décisions très largement fondées sur la donnée.

- **Plan d'action :** Valider les tableaux de bord et les définitions des indicateurs, documenter les pipelines et organiser des revues régulières des modèles (biais, explicabilité).

Score Global — 2,7 / 5

Avec une moyenne de 2,7 sur 5, Spotify se situe entre le niveau « **Reactive** » et « **Proactive** » par rapport à l'échelle de maturité. Le profil est très contrasté. L'entreprise est en avance sur ce qui crée directement de la valeur pour l'utilisateur : l'analytics et le moteur de recommandation (4/5), puis l'architecture, la sécurité et l'usage des données (3/5). En revanche, les fondations transverses de la gouvernance sont en retard : métadonnées (2/5), intégration (2/5), qualité et conformité (2,5/5).

Ce décalage s'explique par une croissance très rapide. Chaque département a développé ses propres données avec ses propres règles, sans cadre commun. Spotify sait donc très bien exploiter ses données, mais ne les gouverne pas encore à l'échelle globale de l'entreprise. L'amende de 2023 en est un bon exemple : il est difficile de restituer toutes les données d'un utilisateur quand elles sont réparties dans des silos, sans catalogue ni identifiant commun.

L'enjeu n'est donc pas de tout reconstruire, mais de fédérer et de structurer l'existant. Il faut une politique commune, des rôles clairs, un catalogue, une gestion industrialisée des droits des utilisateurs et des formations. L'objectif est d'atteindre un niveau d'environ 4/5 (« **Managed** ») en 18 mois, un horizon cohérent avec l'Executive Q&A Guide (phase pilote de 3 à 6 mois, puis déploiement progressif).

4. Synthèse, défis et stratégie d'implémentation de la gouvernance

Sept défis ressortent du diagnostic. Ils serviront à structurer la politique de gouvernance (présentée dans le Livrable 2) et son plan de mise en œuvre (dans le Livrable 3) :

- **C1 — Supprimer les silos (P1).** Création d'identifiant utilisateur commun afin d'avoir une vue complète de l'utilisateur et ne plus dupliquer les efforts.
- **C2 — Industrialiser les droits des personnes et le consentement (P1).** La sanction de l'IMY en 2023 (≈ 5 M€) montre que le risque est réel ; l'exposition maximale peut atteindre 4 % du chiffre d'affaires.
- **C3 — Documenter les données (P1).** Mettre en place un Data Catalogue, le lineage et un marquage des données personnelles, pour savoir où elles se trouvent.

- **C4 — Fiabiliser la qualité** (P2). Fixer des règles communes, automatiser les contrôles et formaliser des data contracts, afin de mieux alimenter le moteur de recommandation.
- **C5 — Renforcer la sécurité** (P2). Gérer les accès selon la sensibilité des données, chiffrer les données de facturation (PCI-DSS) et mener des audits réguliers.
- **C6 — Encadrer l'IA** (P3). Traitement des biais et l'explicabilité des recommandations, ainsi que les contenus générés par IA, dans le cadre de l'AI Act.
- **C7 — Former à la gouvernance** (transverse). Mettre en place un programme continu, dès le début de la mise en place du plan de gouvernance, pour que la politique soit réellement appliquée.

C1, C2 et C3 sont traités ensemble par le pilote DSAR (Livrable 3). Pour répondre complètement à une demande d'accès, il faut en effet savoir où sont les données, lesquelles sont personnelles et comment les relier.

En conclusion, Spotify dispose des atouts d'une entreprise mature (architecture, analytics, usage de la donnée), mais sa gouvernance reste réactive. Pour atteindre le palier « Managed » ($\approx 4/5$), il faut fédérer les pratiques, industrialiser la qualité et la conformité, et diffuser une culture de la gouvernance.